CIR Rebuttal

AnaToPrint — The Slice is Right

March 23rd, 2026 | Israk A., Greg M., Cooper S., Bryan S., Ethan W.

Introduction

We would like to thank our sister team CollaborAITE for taking the time to conduct a thorough Code Inspection Report (CIR) on our project and for providing well-considered, constructive feedback. We have reviewed each identified issue carefully and have already begun addressing many of them. The sections below outline our response to each defect in turn.

Issue Responses

1	Module	dicomToPng.ts (lines 266-270)	Category	Security / Privacy
	Severity	Critical		
	Defect	downloadOrganizedPngs writes metadata.json into the export zip containing patientID, patientName, patientDateOfBirth, and patientSex. This violates NFR-05: exported files must not contain embedded protected health information. The user is not informed this data is included.		
Team Response		While the DICOM to PNG does write patient data, this is currently only temporary as we work with our other client on G-code development. This will be corrected to comply with NFR-05.		

2	Module	UploadPage.tsx (lines 269-288)	Category	Security / Privacy
	Severity	High		
	Defect	Patient name, ID, DOB, sex, study date, and series description are parsed from DICOM tags and rendered directly in the UI without any PHI minimization or disclosure notice.		
Team Response		Currently none of our patient data is being stored in unauthorized locations. We will add a clear disclosure notice informing users that patient data will be displayed on the upload page.		

3	Module	stlExport.ts (lines 164-186)	Category	Logic Error
	Severity	High		
	Defect	exportToSTL wraps generateSTL in setTimeout(, 0). The try/catch only wraps the setTimeout() call itself, not the callback. Any exception thrown inside the callback will not be caught, leaving the UI in a processing state with no visible error.		

Team Response	Planned for remediation. The try/catch block will be restructured to wrap the callback body, ensuring that exceptions from the marching cubes, smoothing, and STL writing pipeline are properly caught and surfaced to the user.

4	**Module**	stlExport.ts (lines 164-186)	**Category**	Performance
	Severity	**High**		
	Defect	The entire marching cubes + smoothing + STL writing pipeline runs on the main thread via setTimeout(, 0). SDD Section 2.2 specifies a WebWorkerManager for this. Large DICOM datasets will freeze the UI and violates NFR-08.		
Team Response		Additional testing will be done to assess the real-world impact on our use cases. A fix will be implemented if testing confirms unacceptable main-thread blocking.		

5	**Module**	Viewer3D.tsx (lines 122-136)	**Category**	Performance
	Severity	**High**		
	Defect	Cleanup function only calls fullScreenRendererRef.current.delete(). The VTK mapper, volume actor, color transfer function, and opacity function are never .delete()'d, leaking GPU memory every time Viewer3D is remounted.		
Team Response		GPU memory leak remediation is planned and will be addressed in an upcoming cleanup pass.		

6	**Module**	ExportPage.tsx (lines 112-114)	**Category**	Logic Error
	Severity	**High**		
	Defect	A 1.2-second setTimeout fires unconditionally after G-code export. If the user navigates away before it fires, setState is called on an unmounted component. Rapid clicks queue multiple timers. No clearTimeout exists in any cleanup path.		
Team Response		Planned for remediation. A cleanup function using clearTimeout will be added and the setState call will be guarded against unmounted component scenarios.		

7	**Module**	dicomUtils.ts (lines 154-160)	**Category**	Logic Error
	Severity	**High**		
	Defect	readImageDicomFileSeries() is called without try/catch. If the ITK-WASM pipeline fails, the webWorkerPool is never terminated, causing a resource leak.		
Team Response		All resource leak issues, including this one, are planned to be addressed together in an upcoming remediation pass.		

8	**Module**	UploadPage.tsx (lines 94-96)	**Category**	Logic Error
	Severity	**Medium**		

	Defect	The traverseFileTree helper uses entry.file() with a callback wrapped in a Promise, but the Promise has no reject path. If entry.file() fails, the Promise hangs forever.
Team Response		Assessed as non-critical. Planned to be addressed during upcoming code cleanup if time permits.

9	**Module**	useDicomUpload.ts (lines 65-76)	**Category**	Logic Error
	Severity	**Medium**		
	Defect	loadDicomImageSeries() and convertItkToVtkImage() are called inside loadSeries without individual try/catch. If conversion fails between state updates, the UI can get stuck in a permanent loading state.		
Team Response		Assessed as non-critical. Planned to be addressed during upcoming code cleanup if time permits.		

10	**Module**	dicomToPng.ts (line 277)	**Category**	Logic Error
	Severity	**Medium**		
	Defect	zip.generateAsync({ type: "blob" }) has no .catch() handler. A corrupted zip operation will silently fail with no user feedback.		
Team Response		Assessed as non-critical. Planned to be addressed during upcoming code cleanup if time permits.		

11	**Module**	dicomUtils.ts (lines 185-187)	**Category**	Logic Error
	Severity	**Medium**		
	Defect	groupDicomFiles uses "unknown" as the fallback for missing IDs. If two different patients both have missing IDs, their scans are merged into the same bucket and treated as one patient.		
Team Response		Assessed as non-critical. Planned to be addressed during upcoming code cleanup if time permits.		

12	**Module**	ErrorBoundary.tsx (lines 33-36)	**Category**	Security / Privacy
	Severity	**Medium**		
	Defect	When the application crashes, the raw error message is displayed directly in the UI via a <pre> tag, potentially exposing stack traces, file paths, and implementation details.		
Team Response		This is a valid concern we had not fully considered. We plan to replace the raw error output with a user-friendly message and ensure stack traces are not exposed in production.		

13	Module	stlExport.ts / dicomToPng.ts	Category	Security / Privacy
	Severity	Medium		
	Defect	User-controlled filenames are used directly in download link href/download attributes without sanitization. Malicious filenames could potentially cause unexpected behavior.		
Team Response		Another file path security concern we had not planned for. Filename sanitization will be added to the relevant export paths.		

14	Module	Multiple files	Category	Security / Privacy
	Severity	Low		
	Defect	console.error and console.warn calls throughout the codebase leak implementation details, error objects, and stack traces to the browser console.		
Team Response		Assessed as low priority. Will be addressed during cleanup if time permits; sensitive detail logging will be stripped from production builds.		

15	Module	Dependency tree	Category	Security / Privacy
	Severity	Medium		
	Defect	Running npm audit reveals multiple known CVEs in the project's dependency tree. No evidence of regular audit or remediation.		
Team Response		Assessed as lower priority for the current phase. Dependency auditing and remediation will be incorporated as the project matures.		

16	Module	UploadPage.tsx	Category	UI / Usability
	Severity	Medium		
	Defect	No file type validation on drag-and-drop. Any file type is accepted and passed to the DICOM parser, wasting CPU on files that will never parse successfully.		
Team Response		An implementation to reject non-DICOM files before parsing will be added.		

17	Module	UploadPage.tsx	Category	UI / Usability
	Severity	Medium		
	Defect	The file browser uses webkitdirectory, which only allows folder selection. DICOM files cannot be individually selected from the file explorer.		

Team Response	DICOM folder selection functions for both standard upload and drag-and-drop. Individual slice selection only works via drag-and-drop; this limitation will be documented in the user manual and README.

18	**Module**	Upload flow	**Category**	Correctness
	Severity	**Medium**		
	Defect	No file size validation exists anywhere in the upload pipeline. The UIDD specifies a max 1.0 GB file size limit. Currently the only limit is available browser memory.		
Team Response		The 1.0 GB limit was set before we understood average DICOM file sizes and confirmed the pipeline functions without a hard cap. We plan to revise the requirement to reflect realistic usage.		

19	**Module**	Viewer3D.tsx	**Category**	Correctness
	Severity	**Medium**		
	Defect	UIDD DV-04 specifies a surface/volume render mode toggle. No render mode selector exists in the UI; only volume rendering is implemented.		
Team Response		Only volume rendering implemented due to change of plans we will remedy this UIDD error.		

20	**Module**	Application-wide	**Category**	Correctness
	Severity	**Medium**		
	Defect	UIDD 3.3 specifies FPS display in the status bar. No FPS monitoring or display is implemented.		
Team Response		Already resolved. FPS display has been implemented.		

21	**Module**	SettingsPage.tsx (lines 6-8)	**Category**	UI / Usability
	Severity	**Low**		
	Defect	The 'Save Settings' button only calls alert("Settings saved successfully!"). Actual saving happens automatically through updateSettings on every change, making the button misleading.		
Team Response		The redundant Save Settings button will be removed.		

22	**Module**	storage.ts	**Category**	Logic Error
	Severity	**Low**		

	Defect	Settings persistence uses sessionStorage rather than localStorage. Settings are lost when the browser tab is closed. A code comment suggests localStorage was the intended implementation.
Team Response		The use of sessionStorage was intentional — we opted for session-only persistence to avoid any risk of patient data being retained across sessions. We consider this the safest approach for a medical application.

23	**Module**	ExportPage.tsx	**Category**	Logic Error
	Severity	**Medium**		
	Defect	The G-code export path has an inner try/catch with user-facing error handling. The STL export path has no equivalent — errors in generateSTL are silently swallowed. Inconsistent error handling between export paths.		
Team Response		Assessed as non-critical. Planned to be addressed during upcoming code cleanup if time permits.		

24	**Module**	Viewer3D.tsx (lines 179-192)	**Category**	Logic Error
	Severity	**Low**		
	Defect	handleReset calls renderer.resetCamera(), then immediately overwrites with hardcoded camera values, then calls renderer.resetCamera() again. The first resetCamera() is pointless.		
Team Response		Assessed as low impact. Planned to be addressed during upcoming code cleanup if time permits.		

25	**Module**	package.json (root)	**Category**	Coding Convention
	Severity	**Low**		
	Defect	The jszip and @types/jszip dependencies are declared in the root package.json rather than in webapp/package.json, which is the package that actually imports them.		
Team Response		An easy fix that will be addressed promptly.		

26	**Module**	ExportPage.tsx / UploadPage.tsx	**Category**	Coding Convention
	Severity	**Medium**		
	Defect	Both are oversized components mixing business logic, state management, file traversal, and UI rendering, reducing testability and maintainability.		
Team Response		Already addressed. These components have been decomposed into smaller units with separated concerns.		

27	Module	Multiple files	Category	Coding Convention
	Severity	Low		
	Defect	TypeScript any casts are used at important points in useDicomUpload.ts, UploadPage.tsx, and SettingsPage.tsx, bypassing TypeScript's type safety.		
Team Response		Assessed as low priority. Planned to be addressed during upcoming code cleanup if time permits.		

28	Module	Application-wide	Category	Coding Convention
	Severity	Low		
	Defect	Inconsistent color tokens across the site. Tailwind utility classes use ad-hoc color values with no central color theme or design token system.		
Team Response		Already resolved. A consistent color token system has been implemented.		

29	Module	Multiple components	Category	Coding Convention
	Severity	Medium		
	Defect	Insufficient code comments throughout the codebase. React components and hooks are largely uncommented. Given that ~15k lines were committed by a single developer, this is a significant maintainability risk.		
Team Response		We plan to add inline comments systematically as we clean up the codebase in the coming weeks.		

30	Module	Application-wide	Category	Security / Privacy
	Severity	Low		
	Defect	No user authentication is implemented. For a medical application handling PHI, this is worth noting depending on the deployment scenario.		
Team Response		User authentication was not included in our original requirements or project scope, though we acknowledge it is a valid recommendation for a medical-grade deployment.		

Closing Statement

In the coming weeks, we plan to systematically address the remaining coding issues — whether they relate to convention, logic errors, security, or performance — with appropriate testing to ensure stability is maintained throughout. Where we are proceeding with existing implementations, our rationale has been provided above. We again express our sincere

gratitude to CollaborAITE for their time and effort in helping us deliver a more stable and complete system.

Signatures

Israk A.	Israk Arafat	3/25/26
Greg M.		3/25/26
Cooper S.	Cooper Stepankiw	3/25/26
Bryan S.	Bryan Sturdivant	3/25/26
Ethan W.	Ethan Wyman	3/25/26